Mini Project Review

Shadow AI Prompt Guardian

Under the Guidance of:
Mr. NaveenRaj AP/CSE(IOT)

Team Members:
Ram Sakthi Sharumathi M (713324SB041)
Roopesh S N (713324SB044)
Sanjeevkumar P (713324SB046)
Saravana Kumar M (713324SB048)

Problem Statement

The increasing use of public AI chatbots creates a risk of accidentally sharing sensitive information. Users may unknowingly paste API keys, passwords, personal data, source code, or confidential business information into AI prompts. Once the prompt is submitted, this information may be transmitted to an external AI service.

Traditional DLP solutions may require additional network infrastructure or centralized monitoring. Therefore, a lightweight client-side solution is needed to detect and prevent sensitive data leakage before the prompt is transmitted.

Abstract

- SENTINEL is a client-side Data Loss Prevention (DLP) browser extension.
- It protects sensitive information entered into public AI chatbots.
- It prevents accidental sharing of credentials, PII, source code and confidential data.
- It works directly inside the browser before information is transmitted.
- It supports browser-based AI platforms such as ChatGPT, Claude and Gemini.
- SENTINEL uses a multi-layer detection engine to identify sensitive information.
- More than 150 signature patterns are used to detect known sensitive data.
- Shannon Entropy is used to identify possible unknown secrets.

Abstract

- The Luhn Algorithm is used to validate payment-card candidates.
- PII, passwords, credentials and confidential information are detected locally.
- Text normalization helps detect simple obfuscation techniques.
- High-risk prompts can be blocked before they are transmitted.
- Explainable warnings show users why their prompt was flagged.
- Auto-Redaction replaces sensitive values with safe placeholders.
- Masked security events are stored locally using SHA-256 hash chaining.
- Prompt data and telemetry are not sent to external servers.
- SENTINEL provides a lightweight and privacy-focused approach to AI data protection.

Objectives

- To detect sensitive information in AI prompts before it is transmitted to external AI services.
- To monitor user inputs and provide real-time security warnings.
- To identify API keys, passwords, PII, payment-card data and other confidential information.
- To calculate a risk score and classify detected information based on severity.
- To block high-risk prompts and prevent accidental data leakage.
- To provide automatic redaction so users can safely submit sanitized prompts.

Literature Survey & Gaps

Literature Survey

• Traditional Data Loss Prevention (DLP) systems mainly use network monitoring, proxy servers and centralized security controls.

• Existing security approaches focus on preventing sensitive data from leaving organizational systems.

• AI chatbots introduce a new data-leakage risk because users directly enter information into external AI platforms.

• Existing solutions may not provide real-time, prompt-level protection directly inside the browser.

• There is a need for a lightweight solution specifically designed to inspect AI prompts before transmission.

Literature Survey & Gaps

Research Gaps

- Limited client-side protection specifically focused on AI chatbot prompts.
- Lack of immediate detection and blocking before sensitive data is transmitted.
- Limited user-friendly explanations about why a prompt is flagged.
- Lack of simple automatic redaction for detected sensitive information.
- Need for a privacy-focused approach that performs detection locally without sending prompt data to external servers.

Existing Solutions & Limitations

Existing Solutions

- **Traditional DLP Systems:** Monitor and control sensitive data moving through organizational networks.
- **Network Proxies:** Inspect network traffic and apply security policies before data reaches external services.
- **Endpoint Security:** Monitors user devices and applications to identify potentially sensitive activities.
- **Organizational Policies:** Depend on user awareness and rules to prevent employees from sharing confidential information.
- **AI Usage Controls:** Organizations can restrict or monitor access to external AI platforms.

Existing Solutions & Limitations

Limitations

- These solutions may require additional infrastructure and configuration.
- Manual protection depends heavily on user awareness and careful behavior.
- Network-level monitoring may not provide direct prompt-level feedback.
- Users may not know which part of a prompt contains sensitive information.
- Existing approaches may not provide one-click automatic redaction before submission.

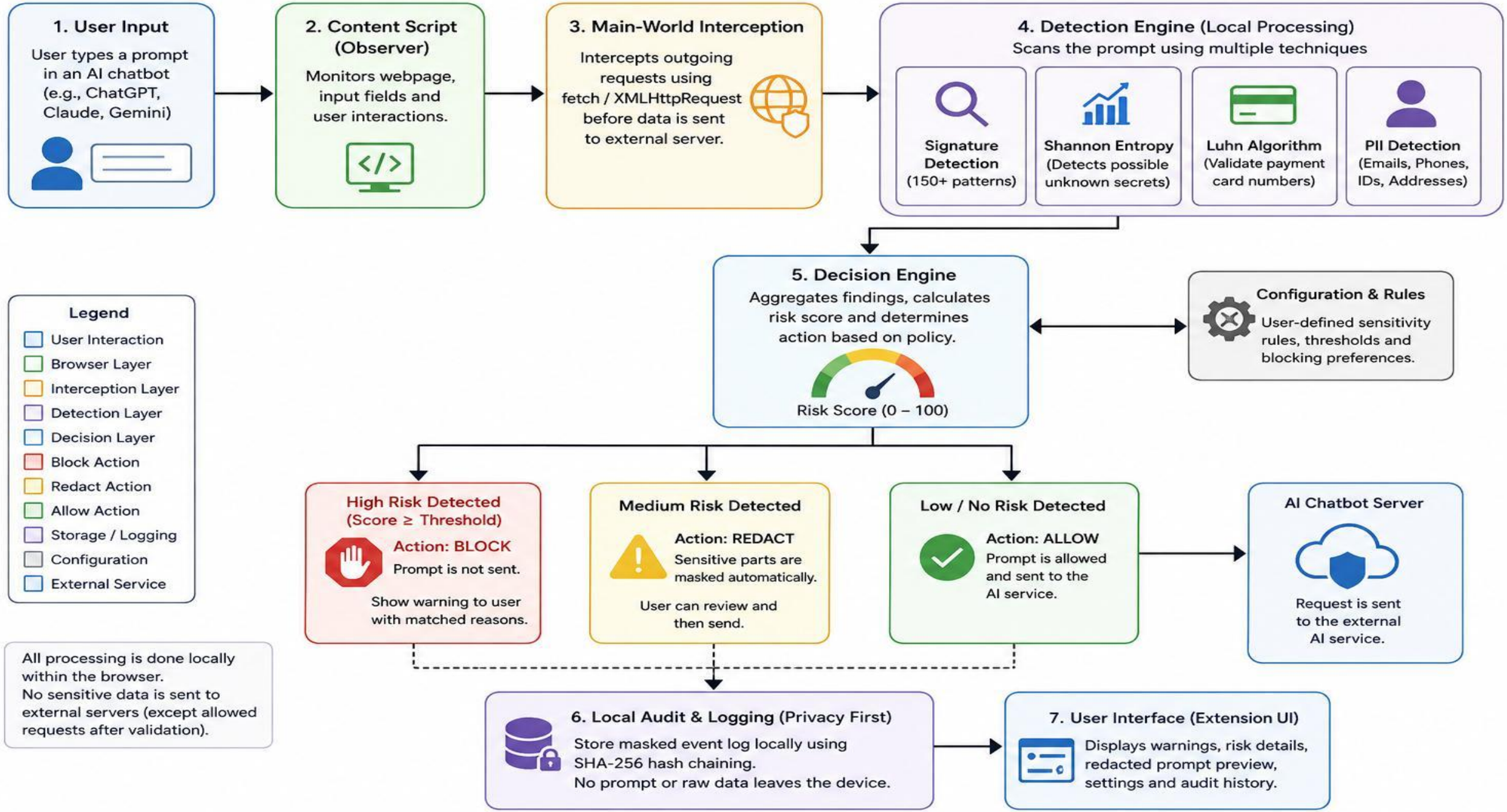
Proposed Solution

- SENTINEL is proposed as a client-side Data Loss Prevention browser extension for AI chatbots.
- It monitors user prompts and detects sensitive information before the request is transmitted.
- The detection engine uses 150+ signatures, Shannon Entropy, Luhn validation and PII detection.
- Detected information is classified according to its type, severity and associated risk score.
- High-risk prompts can be blocked, while sensitive values can be removed using Auto-Redaction.
- The system processes prompts locally and stores only masked audit information in browser storage.

Technology Stack

- HTML5, CSS3 and JavaScript ES6+ are used to develop the browser extension.
- Chrome Manifest V3 provides the extension architecture and security model.
- Service Worker handles background processing and extension events.
- chrome.storage.local stores configuration and masked audit information locally.
- SHA-256 and Luhn Algorithm are used for audit security and payment-card validation.
- Node.js is used for testing and evaluating the detection system.

SENTINEL – System Architecture Flow



Working Methodology

- The user enters or pastes a prompt into a supported AI chatbot.
- SENTINEL monitors the input and intercepts the request before transmission.
- The prompt is normalized and analyzed using multiple detection techniques.
- Detected information is classified based on its type, severity and risk score.
- The system decides whether to Allow, Block or Redact the prompt.
- A masked security event is stored locally for auditing.

Problem Impact (Why it Matters)

- **Data Leakage** → Sensitive information may be exposed to external AI services
- **Credential Exposure** → API keys and passwords may be misused
- **Privacy Risk** → Customer and personal information can be accidentally shared
- **Intellectual Property Loss** → Source code and confidential business data may be exposed
- **Compliance Issues** → Data exposure can lead to privacy and regulatory problems
- **No Immediate Protection** → Users may realize the risk only after submitting the prompt

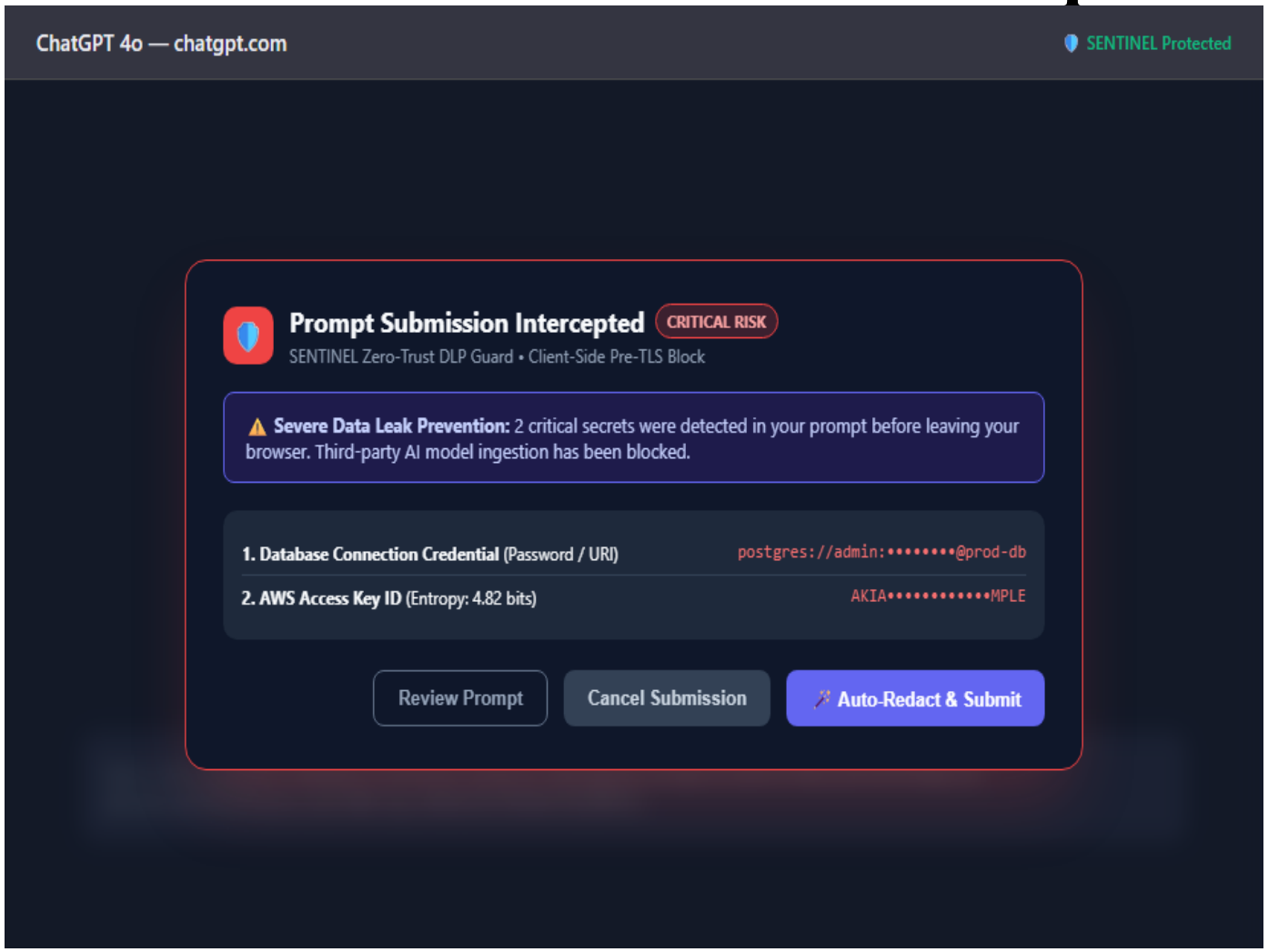
Use Case Scenario

- **Prompt Entry** → Developer pastes authentication code into an AI chatbot for debugging.
- **Sensitive Data** → The code accidentally contains an API key and database credentials.
- **Detection** → SENTINEL scans the prompt and identifies the sensitive information.
- **Warning & Block** → A risk warning is displayed and the request is blocked if the risk is critical.
- **Auto-Redaction** → Sensitive values are replaced with safe placeholders such as [API_KEY].
- **Safe Submission** → The sanitized prompt is submitted to the AI chatbot without exposing the original credentials.

User Flow

- **Open AI Chatbot** → User opens a supported AI platform in the browser.
- **Enter Prompt** → User types or pastes a prompt into the chatbot.
- **Monitor & Scan** → SENTINEL monitors the input and scans for sensitive information.
- **Risk Analysis** → Detected data is classified and a risk score is calculated.
- **Decision** → Prompt is Allowed, Blocked or Redacted based on the risk level.
- **Continue Safely** → User submits the sanitized prompt, while a masked audit record is stored locally.

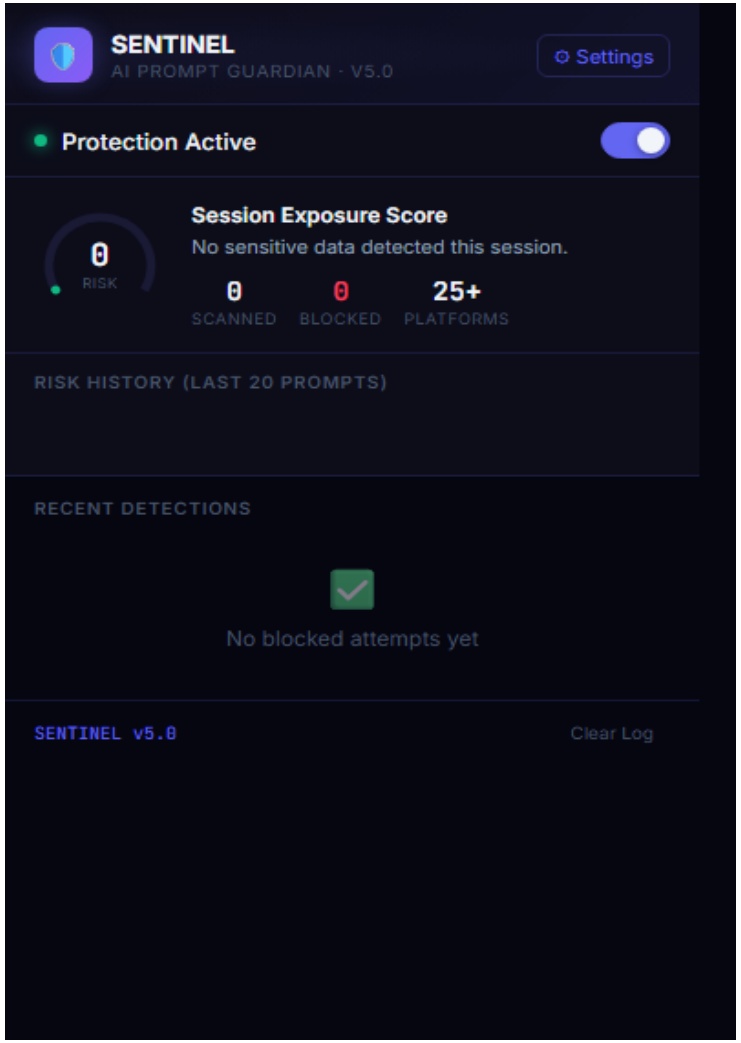
Project Demo: In-Browser Real-Time Interception



Key Demonstration Features:

- Pre-Transmission Interception: Automatically halts submission in ChatGPT before data leaves the browser.
- Critical Risk Banner: Visually alerts the user with severity badges and detailed explanation.
- Matched Secret Breakdown: Identifies Database URI and AWS Access Key with Shannon entropy metrics.
- One-Click Auto-Redact: User can immediately sanitize credentials and submit without manual editing.
- Zero Cloud Egress: Detection executes 100% locally in under 5 milliseconds.

Project Demo: Extension Popup Dashboard



Dashboard Controls & Metrics:

• Protection Status Toggle: Master on/off switch for real-time prompt protection across all supported AI tools.

• Session Exposure Gauge: Visual score reflecting total sensitive data exposure risk in the current browsing session.

• Real-Time Telemetry Counter: Tracks total prompts scanned, leaks blocked, and active platform integrations (25+ AI interfaces).

• Recent Detections Feed: Displays immediate audit history of blocked attempts without exposing raw confidential text.

• Settings & Options Access: Instant navigation to user-defined sensitivity thresholds and custom dictionary lists.

Project Demo: Auto-Redaction & Audit Logging

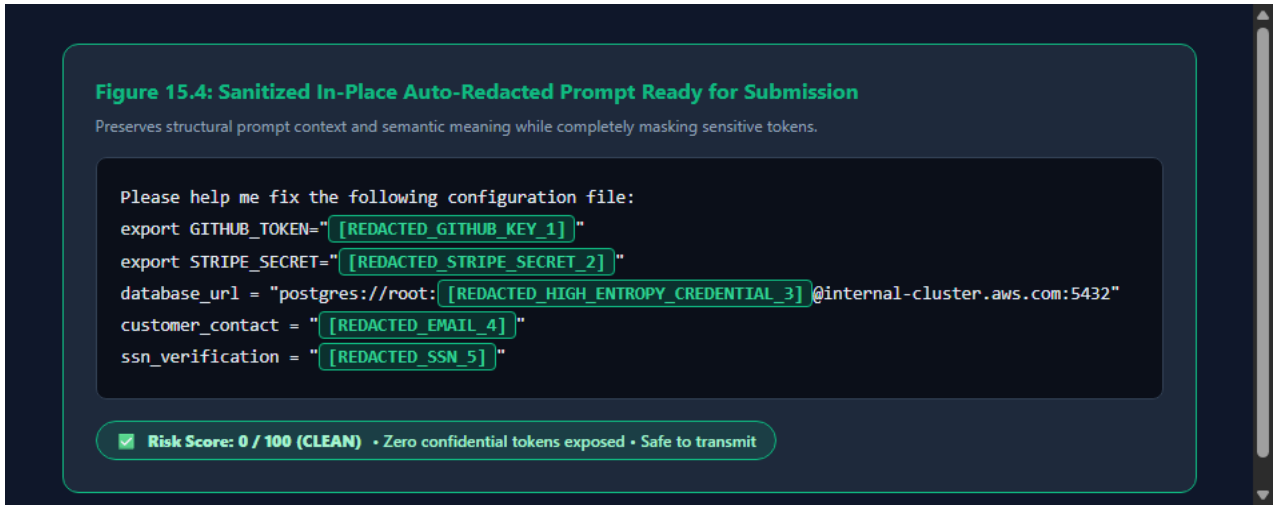


Figure 15.4: Sanitized In-Place Auto-Redacted Prompt Ready for Submission

Preserves structural prompt context and semantic meaning while completely masking sensitive tokens.

```
Please help me fix the following configuration file:
export GITHUB_TOKEN="[REDACTED_GITHUB_KEY_1]"
export STRIPE_SECRET="[REDACTED_STRIPE_SECRET_2]"
database_url = "postgres://root:[REDACTED_HIGH_ENTROPY_CREDENTIAL_3]@internal-cluster.aws.com:5432"
customer_contact = "[REDACTED_EMAIL_4]"
ssn_verification = "[REDACTED_SSN_5]"
```

Risk Score: 0 / 100 (CLEAN) • Zero confidential tokens exposed • Safe to transmit



Figure 15.6: Zero-Trust Local Audit Log Viewer (Encrypted chrome.storage.local)

100% Client-Side Privacy: Stores only masked previews • Zero plain secrets stored

Export Audit Log (JSON)

TIMESTAMP	PLATFORM	THREAT TYPE	SEVERITY	MASKED TOKEN PREVIEW	ACTION TAKEN
2026-09-19 09:12:44	chatgpt.com	OpenAI Secret Key	CRITICAL	sk-proj-••••••••••••••••3xY9	Blocked & Auto-Redacted
2026-09-19 09:14:02	claude.ai	AWS Access Key	CRITICAL	AKIA••••••••••••MPLE	Blocked & User Cancelled
2026-09-19 09:15:19	gemini.google.com	High Shannon Entropy	HIGH	9f8e••••••••••••••••a1b2	Auto-Redacted
2026-09-19 09:15:58	copilot.microsoft.com	US Social Security No.	HIGH	•••-••-9012	Blocked & Auto-Redacted
2026-09-19 09:17:33	perplexity.ai	Confidential Codename	MEDIUM	Project [REDACTED_CODENAME]	User Overridden

In-Place Redaction & Audit Trail:

- In-Place Context Preservation: Automatically replaces secrets with placeholder tags (e.g., [REDACTED_GITHUB_KEY_1]) while keeping prompt syntax intact.
- Safe Transmission: Reduces risk score from 100 to 0 (CLEAN), enabling safe submission to external LLMs.
- Zero-Trust Local Audit Viewer: Encrypted audit log stored solely in chrome.storage.local.
- Masked Token Previews: Logs display only masked previews (e.g. sk-proj-••••3xY9, AKIA••••MPLE).
- Export Capability: Allows compliance teams to export structured tamper-evident audit logs in JSON format.

AI Models Explanation

- **Regex Model** → Uses predefined patterns to detect known API keys, passwords, tokens and sensitive data.
- **Shannon Entropy** → Measures the randomness of text to identify possible unknown secrets.
- **Luhn Algorithm** → Validates possible payment-card numbers and reduces incorrect detections.
- **PII Detection** → Identifies personal information such as email addresses and phone numbers.
- **TF-IDF + Logistic Regression** → Experimental machine-learning model used to classify prompts based on their text features.
- **Combined Detection** → Multiple techniques work together to improve sensitive-data detection and risk assessment.

Innovation

- **Pre-Transmission Protection** → Detects sensitive information before the prompt reaches the external AI service.
- **Multi-Layer Detection** → Combines 150+ signatures, entropy, Luhn validation and PII detection.
- **Privacy-First Processing** → Performs prompt analysis locally without sending prompt data to external servers.
- **Auto-Redaction** → Automatically replaces detected sensitive values with safe placeholders.
- **Explainable Alerts** → Clearly shows users what type of sensitive information was detected and why.
- **Tamper-Evident Audit** → Uses SHA-256 hash chaining to maintain secure local audit records.

Data Flow (Technical)

- **Prompt Input** → User enters or pastes the prompt into the AI chatbot interface.
- **Content Script** → Monitors the webpage, input fields and user interactions.
- **Request Interception** → fetch and XMLHttpRequest requests are intercepted before transmission.
- **Detection Engine** → Prompt is normalized and scanned using Regex, Shannon Entropy, Luhn and PII detection.
- **Decision Engine** → Calculates the risk level and decides whether to Allow, Block or Redact the request.
- **Local Storage** → Masked audit information and configuration are stored using chrome.storage.local.

Results & Discussion

- **High Detection Accuracy** → The system achieved 100% accuracy on the evaluated test dataset.
- **Reliable Detection** → Precision and recall were both reported as 100%, with an F1 score of 1.00.
- **Low False Positives** → The reported false positive rate was 0%, reducing unnecessary security warnings.
- **Fast Processing** → Average detection latency was reported to be under 25 ms.
- **Test Coverage** → The evaluation included 95 prompts covering clean prompts, API keys, passwords, PII and confidential data.
- **Overall Result** → SENTINEL demonstrated effective real-time sensitive-data detection while maintaining local, privacy-focused processing.

Challenges & Solutions

- **Dynamic AI Websites** → MutationObserver detects changes in webpage elements and maintains monitoring.
- **React-Controlled Inputs** → Native setters and synthetic events help synchronize monitored input fields.
- **Obfuscated Data** → Text normalization handles unusual spacing, invisible characters and Unicode variations.
- **Encoded Secrets** → Base64 content is decoded and scanned again for sensitive information.
- **False Positives** → Entropy thresholds and Luhn validation help improve detection accuracy.
- **Browser Limitations** → The current system focuses on browser-based AI platforms rather than terminal applications.

Future Scope & Conclusion

Future Scope:

• OCR Integration: Detect sensitive data inside screenshots and image attachments.

• Enterprise SIEM: Export alerts to centralized corporate monitoring platforms.

• Cross-Browser Support: Extend extension support to Firefox and Safari.

• On-Device Machine Learning: Lightweight TensorFlow.js models for semantic leaks.

• Multi-Platform Coverage: Support emerging enterprise AI platforms and agents.

Conclusion:

• Effective Protection: Prevents irreversible corporate data leakage to public AI chatbots.

• Synchronous Pre-TLS Interception: Halts sensitive prompts before network transmission.

• Privacy-Preserving Design: 100% client-side evaluation with zero cloud telemetry.

• Zero Human-Perceptible Lag: Sub-25ms response time ensures seamless user productivity.

• Practical & Deployable: Lightweight Manifest V3 architecture ready for enterprise rollout.


Thank
you!